

Planning Report:

Automated External Attack Surface Mapping (ASM)

Student: Arvin Allahbakhsh, arvina@chalmers.se

Company: Nordic Defender, <https://nordicdefender.com/>

Company Supervisor: Mahsima Jalooli, mahsima.jalooli@nordicdefender.com

Chalmers Supervisor: Sakib Sisteek

Language: English

Workload: 20 hours/week

Project Description

Field: Cybersecurity - Attack Surface Management (ASM)

1. Background

Nordic Defender is an international cybersecurity company specializing in modern defense solutions. In the current era of “Vibecoding” and AI-assisted development, the speed of software production has increased exponentially. While this allows both professionals and hobbyists to deploy applications rapidly, it often leads to a “security debt” where cloud infrastructures, subdomains, and APIs are published without proper security audits. As these digital footprints grow, forgotten or misconfigured assets become major entry points for attackers. Attack Surface Mapping (ASM) is the vital process of discovering and monitoring these external assets from an attacker’s perspective.

2. Purpose

The purpose of this project is to provide Nordic Defender and independent developers with a high-performance, automated tool to gain an “outside-in” view of their digital footprint. The project aims to reduce the risk of exploitation due to forgotten or misconfigured infrastructure by identifying “Unknown and Exposed” assets.

3. Problem Description

Manual identification of these assets is time-consuming and prone to human error. Existing tools often lack the speed, the specific logic needed to filter out noise from actual threats or are too complex for non-security professionals. Nordic Defender, as a cybersecurity firm, sees a constant need for efficient ways to help clients find these “open windows” before they are exploited by hackers. This project addresses the need for a high-performance, automated tool that identifies “Shadow IT” and moves assets from an “Unknown and Exposed” state to a “Known” state.

4. Goals & Objectives

The goal of this thesis is to develop a standalone software module that automates the discovery and analysis of a company's external assets using public Open Source Intelligence (OSINT) data.

Key Tasks include:

- **Performance Evaluation:** A core objective is to evaluate the efficiency of GoLang compared to Python in building a high-performance scanning engine.
- **Asset Discovery:** Implementing logic to scan public DNS records, certificate transparency, logs and IP ranges to find subdomains and hidden servers.
- **Service Fingerprinting:** Developing a scanning engine to identify what software and versions are running on discovered ports to detect vulnerabilities (e.g, identifying an outdated Apache server).
- **Data Modeling** Structuring the discovered data in a way that allows for easy tracking of changes over time (e.g, using a PostgreSQL database).

5. Limitations (Delimitations)

To ensure the project is academically rigorous and feasible within the timeframe, the following limitations are set:

- **Data Confidentiality & Access:** Due to strict confidentiality agreements with Nordic Defender, the project is strictly limited to information that can be gathered without accessing proprietary company data or internal client systems.
- **Exclusion of UI/UX Design:** To prioritize the technical performance and benchmarking of the backend engine (GoLang vs. Python), the development of a graphical user interface is excluded from the scope. The tool will operate as a Command Line Interface (CLI).
- **Data Scope:** The tool will strictly utilize public OSINT data to maintain confidentiality.
- **Breadth of OSINT Sources:** While the engine seeks to map the attack surface, it will focus on major public records (DNS, SSL/TLS certificates). It will not attempt to scrape private social media or dark web forums, as this would introduce ethical and legal complexities beyond the project's scope.
- **Infrastructure:** Testing is limited to a sandboxed Docker environment to prevent interference with live networks.
- **No Automated Remediation:** The tool is designed for **discovery and mapping** only. It will not include features to automatically "fix" or patch found vulnerabilities, as this requires administrative access and introduces significant risk to the target infrastructure.
- **Network Constraints:** The scanning speed and depth are limited by standard network rate-limiting to avoid being flagged as a malicious Denial of Service (DoS) attack.

6. Methodology & Implementation

The project follows a linear Waterfall approach through the whole project.

- 1. **Research & Setup:** Comparative evaluation of Python vs GoLang for network scanning. Setting up the sandboxed Docker environment and implementing basic DNS discovery logic.
- 2. **Requirements Analysis:** Defining scanning logic and OSINT sources.
- 3. **System Design:** Core development of the scanning engine, focusing on Asset Discovery and Service Fingerprinting algorithms.
- 4. **Data Modeling:** Structuring the discovered data within a PostgreSQL database.
- 5. **Implementation:** implementing and finalizing the ASM engine.
- 6. **Verification:** Testing, bugfixing, benchmarking execution time.
- 7. **Finalization:** Final analysis and thesis report completion, finalizing the presentation.

The project will be carried out by the student with technical guidance and industry best practices provided by Nordic Defender. While the student is responsible for the coding and execution, Nordic Defender will provide guidelines, tips, and expert feedback to ensure that tool’s relevance to the cybersecurity market. Since Nordic Defender handles sensitive data, this project is designed to use only public data. This ensures that the final report remains a public document without compromising company or client confidentiality. All development and testing will be conducted in a sandboxed Docker environment to ensure security and maintainability.

7. Societal & Ethical Aspects

The developed tool utilizes public OSINT data to identify vulnerabilities, which introduces a "dual-use" dilemma. While the tool is designed for defensive purposes, to help organizations and developers secure their infrastructure, it could theoretically be used by malicious actors. To mitigate this, the final report will focus on defensive methodologies and the importance of responsible disclosure.

8. Project Timeline (Gantt Chart)

All phases are based on 20 hours of work per week.

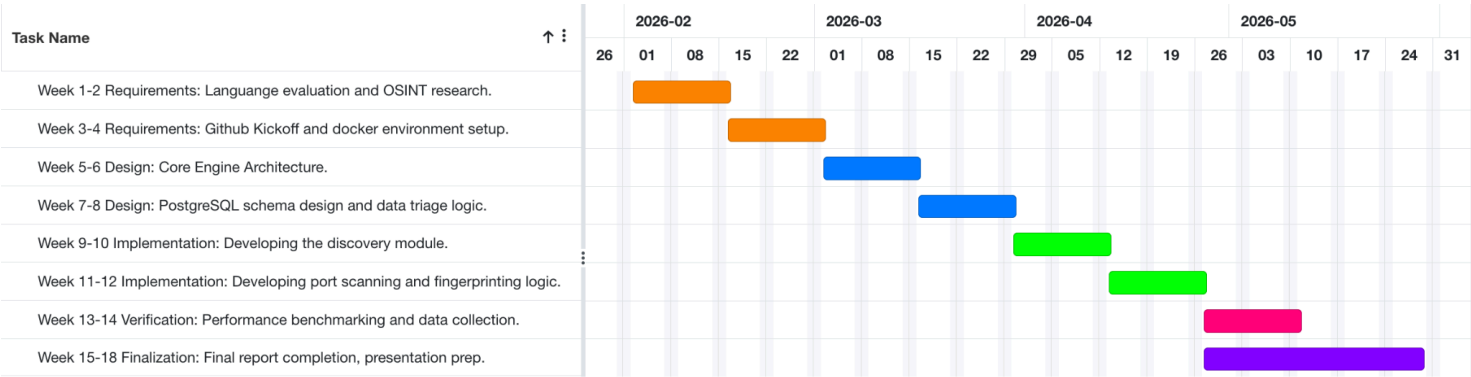


Figure 1: Project timeline illustrating the Waterfall phases from February to May 2026.